

CERN develops a detailed open science policy

CERN (European Council for Nuclear Research) established a new open science policy for itself, which comes into immediate effect, during its 209th session in September this year. The goal of the policy is to make all CERN research completely open, inclusive, democratic, and transparent for other researchers as well as for the general public. The Open Science Strategy Working Group (OSSWG), which has representatives from each CERN department, developed this policy. A web page dedicated to detailing all the open scientific projects at CERN has been published together with the policy statement.

The finalised policy was developed in response to the European Strategy for Particle Physics' 2020 update, which emphasised the value of open science, and the UNESCO Recommendation on Open Science, which was released in 2021. Right since the CERN Convention was ratified at UNESCO in 1952, open science has been one of the organisation's guiding principles.



All research publications, experimental data, and research software and hardware will be made publicly available under the new policy, which also incorporates the previous rules for open access, open data, and open source software and hardware. Additionally, it combines other open science tenets such as training, outreach, and citizen science, which aim to inform and engage the public and the next generation of researchers.

DevOps engineers can monitor and enforce their GitHub configurations in a secure and scalable manner with the aid of Legitify, a GitHub misconfiguration checker. With support for Windows, Mac, and Linux, Legitify is a cross-platform security solution that offers only a small portion of the features offered by the larger Legit Security platform.



Software developers all across the world utilise GitHub, a very well-liked source code management (SCM) solution at the centre of many enterprises' software supply chains. However, because GitHub is a complicated product, managers may fail to notice incorrect configurations and insecure default settings, which can lead to security flaws that jeopardise an organisation's software supply chain.

Due to the distinct configurations and protections necessary for each repository, ensuring security across big GitHub installations was challenging and time consuming prior to the advent of open source Legitify. It took a lot of manual work and the efforts of a large GitHub group to consistently enforce security were prone to error.

Along with Legitify, Legit Security has given back to the online security community by responsibly disclosing more GitHub flaws found by its in-house security research team. Legit Security also participates actively in groups like OpenSSL and the Linux Foundation, where it helps to advance the security of the software supply chain and safe software development in general.

Managing security issues in the open source world is important

Extensively used open source projects are today being maintained by a limited number of engineers. These engineers are unable to provide voluntary time and effort completely to the job since they also need to pay their bills.

For more complex open source projects, this can be a problem. As an illustration, the Linux kernel project consists of more than 30 million lines of code, contains hundreds of flaws that need to be resolved, and has close to 2000 active developers. Each active developer has written more than 15,000 lines of code.

According to recent research from the Linux Foundation, an application has an average of 5.1 significant vulnerabilities that are still open, and 41 per cent of enterprises lack confidence in the security of their open source software. To make matters worse, only 49 per cent of businesses have an open source security policy.

Since OSS updates and patches must be implemented to secure systems, this requirement can bring unique difficulties. Updating mission-critical software could result in functionality loss and/or unplanned downtime if the solution depends on a certain software version. When a situation is business-critical, it may be more elegant to hire a specialist to backport the patch, and maintain a version for longer than the larger community is willing to.